Each time someone tries to open the folder or a file inside it, the system checks the ACL to decide whether to allow the requested action. Access is determined by the list attached to the folder, not by a centralized policy or the principal's organizational role. As the permissions that Alice has set demonstrate, that list can reference organizations, not just individuals.

Just like a bouncer checking names at the door of a private party, an ACL serves as a guest list associated with the resource. The list doesn't care who you are within the broader organization; it only matters whether your name is on the list and what type of access you've been granted. Alice might be the head of marketing, but if her name isn't on the ACL, she won't get in.

Access Control Lists (ACLs) are a foundational authorization model where permissions are assigned directly to the resources being protected. Each resource—whether a file, database record, or network share—has an associated list that specifies which principals can access it and what operations they're allowed to perform.

An ACL is essentially a table attached to a resource, where each entry includes:

- Principal: the user or group the rule applies to
- Permissions: the actions that the principal is allowed (or denied) to perform

This model is *resource-centric*—access control logic is stored with the resource itself, rather than being maintained in a centralized policy or identity system. When a principal tries to perform an action, the system checks the ACL on the resource to determine if that action is permitted.

Figure 5.1 illustrates this model: a shared folder containing marketing campaign plans is protected by an ACL that lists Alice, Bob, and the Marketing team, along with their respective permissions. The ACL is evaluated at the time of access based solely on what is listed for each principal.